ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell Automation PowerFlex 525 (520-series) AC Drive · Component type: **Embedded Device (EDR) - compact variable frequency drive (VFD)** · Target SL = SL 3

Where to work	**Connected Components Workbench (CCW)** via FactoryTalk Linx/RSLinx; the drive's **LCD keypad** (integral HIM); **Studio 5000** drive AOP when Logix-connected; the embedded **EtherNet/IP web page**. Firmware via **ControlFLASH / CCW**.
Parameter groups	520-series params use a letter+number scheme: **b** (Display), **P** (Basic Program), **t** (Terminals), **C** (Communications), **L**/**d**/**A** (Logic/Diagnostic/Advanced). EtherNet/IP config & comm-fault behavior live in **Group C** (e.g. C128-C140 IP, C125/C143/C144 comm-loss).
Notes	EDR - 520-series compact AC drive (PowerFlex 523/525; 525 = networked). Confirm firmware rev and comm path (embedded EtherNet/IP vs DSI). **Important:** the 520-series has a limited native security stack - no CIP Security, no drive-level FactoryTalk Security, no HIM login. Segmentation + Logix-side controls are the primary SL-3 compensating controls; document them explicitly.
How to read	Read-only: review the CCW parameter set, keypad values, and the embedded web page. Native how-to (exact group/param) + external-tool validation + pass, with honest Partial/Compensating where native controls are thin. Scans authorized; fuzz ISOLATED lab only.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	The 520-series drive has **no per-user login and no keypad password**. Authentication is enforced at the layers around it: when Logix-connected, engineering access to the drive AOP is governed by **FactoryTalk Security**; CCW/RSLinx access is controlled on the engineering workstation. **Verify** those are in place and record the drive-level absence as a residual. **Test:** confirm no unauthenticated path (e.g. open web/CIP) can change parameters from outside the cell. **Ext. tools:** FactoryTalk Admin Console (users); Nmap/CCW (attempt external param write - must fail at the zone).	Access authenticated at Logix/EWS/zone layers; drive-level absence documented as residual.	Partial/Compensating.
SR/CR 1.2	Software process / device identification	Confirm the drive is uniquely identified: in CCW read the embedded-EtherNet/IP **Group C** params - IP (C128-C130), subnet (C131-C133), gateway (C134-C136), and host/EN address; each comm partner has a distinct EtherNet/IP identity. **Ext. tools:** CCW (Group C IP params); Wireshark (partner identity).	Unique drive identity; comm partners identified.	
SR/CR 1.3	Account management	No drive accounts exist; manage the accounts that reach it - FactoryTalk users/roles for the AOP and OS accounts on the engineering workstation - least privilege, no defaults, no shared logins. **Ext. tools:** FactoryTalk Admin Console; EWS local/AD accounts.	Surrounding accounts managed/least-privilege; drive has none by design.	Compensating.
SR/CR 1.4	Identifier management	Confirm a unique drive identity (EtherNet/IP address + host name in Group C + nameplate serial); no address reuse across drives; unique FactoryTalk user IDs. **Ext. tools:** CCW device info; network inventory; FactoryTalk.	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Enforce strong authenticators where they exist - FactoryTalk password policy and EWS OS policy. If the embedded web server or any SMTP/email-on-fault feature is enabled, ensure it exposes no unauthenticated write; prefer disabling it (see 7.6). **Ext. tools:** FactoryTalk password policy; embedded web/SMTP check.	Strong managed authenticators at surrounding layers; unneeded services off.	Compensating.
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A at the drive.** The 520-series does not support CIP Security / device certificates. Record N/A with justification; confidentiality/integrity is provided by segmentation and by TLS at the SCADA/EWS layer. **Ext. tools:** Confirm no CIP Security capability on the adapter.	N/A at drive (no PKI support); compensating TLS/segmentation upstream.	N/A
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm CCW/FactoryTalk logon and EWS login mask password entry (drive itself has no login prompt). **Ext. tools:** Visual verification.	Authenticators obscured at the interfaces that have them.	
SR/CR 1.11	Unsuccessful login attempts	Enforce lockout at the layers that authenticate (FactoryTalk lockout policy, EWS/AD lockout). The drive has no login to lock; note as residual. **Ext. tools:** FactoryTalk / AD lockout policy; SIEM failed-auth.	Lockout at surrounding layers; drive residual noted.	Compensating.
SR/CR 1.12	System use notification	No drive banner; enforce the approved use notice on the EWS (GPO) and HMI. **Ext. tools:** EWS GPO / HMI banner review.	Use notice at EWS/HMI (compensating).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the drive EtherNet/IP is reachable only from the trusted cell zone behind the cell firewall / Stratix ACLs; remote engineering only via VPN; deny drive access from untrusted networks. **This is the key control for a light-security drive.** **Ext. tools:** Nmap (from untrusted side - expect no reach); firewall/ACL review.	Access from untrusted networks denied; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Constrain who can command the drive: set the command sources deliberately - P046/P047/P048 [Start Source 1/2/3] and P047/P049 [Speed Reference] - so control comes only from the intended master (e.g. EtherNet/IP from the authorized PLC), and lock down FactoryTalk rights for the AOP. **Test:** from an unauthorized source, attempt Start - it must not take control. **Ext. tools:** CCW (P046-P049 source params); attempt unauthorized Start (isolated).	Command sources constrained to authorized master; FactoryTalk rights least-privilege.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the engineering laptop and any USB used for firmware; removable-media policy on the EWS; only authorized CCW projects loaded. **Ext. tools:** Physical inspection; EWS removable-media policy.	Portable/engineering media controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code on the drive; confirm only drive firmware + parameters run and the embedded web content is vendor read-only (no script path). **Ext. tools:** CCW / embedded web review.	Only trusted firmware/config runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm CCW and EWS sessions time out on inactivity and require re-auth (drive has no session concept). **Ext. tools:** CCW / EWS timeout config.	Engineering sessions lock/timeout; re-auth required.	Compensating.
SR/CR 2.6	Remote session termination	Confirm remote engineering (RDP/VPN to the EWS) can be terminated and idle sessions close; CIP connections to the drive are limited by the adapter. **Ext. tools:** EWS/VPN session review; adapter connection review.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent CIP connections to the embedded adapter are bounded (the 520 adapter has a fixed connection limit) so simultaneous conflicting control is prevented. **Ext. tools:** Adapter connection review; Wireshark.	Concurrent connections bounded/monitored.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.8	Auditable events	The drive keeps a fault queue but no user-attributed audit. Capture configuration/firmware changes in **FactoryTalk AssetCentre** (Audit + DR) with the acting user, and forward EWS/FactoryTalk events to the SIEM; read the drive fault queue (b007-b009 fault codes / CCW faults). **Ext. tools:** AssetCentre audit; CCW fault queue; SIEM.	Changes audited/attributable via AssetCentre/EWS; drive faults captured.	Compensating.
SR/CR 2.9	Audit storage capacity	Drive fault queue is a small fixed depth; retention is via AssetCentre / SIEM - confirm sizing and threshold alerting. **Ext. tools:** AssetCentre DB sizing; SIEM retention.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/AssetCentre alerts on forwarding/collection failure. **Ext. tools:** SIEM / AssetCentre health alerting.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	The drive has no RTC; event time comes from the controller/AssetCentre - confirm those are NTP-synced. **Ext. tools:** NTP / controller time review.	Reliable, synchronized timestamps for drive events.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: keep the drive in a locked cabinet; secure the **DSI** port, the USB firmware port, and the option-card slot. Optionally disable local keypad Start by setting the Start Source to network-only (P046) so a local operator cannot start from the keypad. **Ext. tools:** Physical inspection; CCW (P046 start source; disable unused ports).	Physical/diagnostic interfaces controlled; local start disabled where required.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	The 520-series EtherNet/IP is **unauthenticated cleartext CIP** (no CIP Security). Provide integrity/confidentiality by containing it in a segmented cell zone and terminating TLS at the SCADA/EWS layer; confirm no drive CIP traffic crosses a zone boundary in cleartext. **Ext. tools:** Wireshark (confirm cleartext CIP stays in-zone); firewall rule review.	Drive comms contained to the segmented zone; no cleartext CIP across boundaries.	Compensating.
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Rockwell firmware runs and there is no code-execution path. **Note:** 520-series firmware does not carry the 750-series signed-.dmk guarantee - verify firmware provenance against PCDC and control the update path tightly (2.3/3.10). **Ext. tools:** CCW firmware rev; PCDC provenance check.	Only vendor firmware runs; provenance verified; no code path.	EDR-specific/Partial.
SR/CR 3.3	Security functionality verification	After any change re-verify: command sources (P046-P049), comm-loss actions (C125/C143/C144), embedded web-server state, and IP config, against the hardening baseline; CCW compare against the archived project. **Ext. tools:** CCW compare vs baseline; Nmap (web/unused services off).	Security-relevant settings match baseline after change.	
SR/CR 3.4	Software & information integrity	Archive the parameter set / CCW project in AssetCentre and enable change detection so unauthorized parameter/firmware change is detected (the drive has no native write-lock beyond source control). Compare online-vs-offline. **Ext. tools:** AssetCentre change detection; CCW online-vs-offline compare.	Config integrity monitored; unauthorized change detected.	Compensating.
SR/CR 3.5	Input validation	Confirm the drive tolerates malformed EtherNet/IP/CIP frames without faulting or unsafe motion. **ISOLATED only:** fuzz the adapter on a bench drive and watch the fault queue / connection status. **Ext. tools:** ENIP/CIP fuzzer (ISOLATED); Wireshark.	No crash or unsafe motion on malformed input.	Do NOT fuzz production.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.6	Deterministic output	Verify comm-loss/fault reaction so the motor reaches a defined safe state: set C143 [EN Net Loss Action] and C144 [EN Idle Action] (and C125 [Comm Loss Action] for DSI) to Fault/Stop as designed - **do not** leave them on Hold-Last unless a documented reason and redundant hardwired enable exist. Where a hardwired safety/enable circuit is fitted, function-test it. **Ext. tools:** CCW (C125/C143/C144); hardwired enable function test (lab).	Drive faults/stops to a defined safe state on comm loss (not Hold-Last unless justified).	
SR/CR 3.7	Error handling	Confirm graceful fault handling: review the fault queue and disable auto-restart unless justified (A-group restart params) so errors do not cause unsafe restart. **Ext. tools:** CCW (fault queue; auto-restart/A-group params).	Graceful fault handling; no unsafe restart.	
SR/CR 3.8	Session integrity	**N/A at drive (no secured session).** Legacy CIP sessions are unauthenticated; integrity is provided by containment. Record N/A + compensating segmentation. **Ext. tools:** Wireshark (confirm in-zone containment).	N/A at drive; compensating segmentation recorded.	N/A
SR/CR 3.9	Protection of audit information	Protect the AssetCentre audit DB and SIEM store; restrict who can read/clear the drive fault queue. **Ext. tools:** AssetCentre / SIEM access review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware via ControlFLASH / CCW with firmware obtained from PCDC; verify the revision and provenance; plan the update in a maintenance window with rollback to the prior known-good file. (No on-drive signature check like 750-series - provenance discipline is the control.) **Ext. tools:** ControlFLASH/CCW; PCDC checksum/provenance.	Controlled updates from verified source, with rollback.	EDR-specific/Partial.
EDR 3.11	Physical tamper resistance/detection	Keep the drive in a locked, sealed cabinet; control the DSI/USB/option-card; AssetCentre change records and the drive fault queue provide change evidence. **Ext. tools:** Physical inspection; AssetCentre / fault-queue review.	Cabinet locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**N/A at drive.** 520-series provides no signed-boot supplier root of trust. Record N/A with justification; compensate via firmware update-provenance discipline (3.10), physical control, and segmentation. **Ext. tools:** Confirm no secure-boot / signed-firmware root capability.	N/A at drive (no supplier RoT); compensating controls recorded.	N/A
EDR 3.13	Provisioning asset-owner roots of trust	**N/A at drive.** 520-series provides no CIP Security / asset-owner certificate provisioning. Record N/A with justification; asset-owner trust is enforced at the SCADA/EWS layer and by segmentation. **Ext. tools:** Confirm no CIP-Security / certificate-provisioning capability.	N/A at drive (no asset-owner RoT); compensating controls recorded.	N/A
EDR 3.14	Integrity of the boot process	**N/A at drive (no verified/secure boot).** Record N/A; mitigate via controlled firmware provenance (3.10), physical control, and monitoring. **Ext. tools:** Confirm no secure-boot capability; CCW firmware rev.	N/A at drive; compensating provenance/physical controls recorded.	N/A

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, in CCW/keypad reset the drive to factory defaults (P053 [Reset To Defalts] procedure) and clear the option card so configuration is not recoverable. **Ext. tools:** CCW/keypad (P053 reset to defaults).	Sensitive configuration purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**N/A at drive.** No native crypto on the 520-series; disable the embedded web server / any SMTP feature and rely on TLS at the SCADA/EWS layer and segmentation. **Ext. tools:** Confirm no drive crypto; disable web/SMTP (7.6).	N/A at drive; compensating TLS/segmentation upstream.	N/A

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the drive sits in a controlled cell/zone behind a firewall / Stratix ACLs; only required EtherNet/IP flows cross the boundary; no flat convergence with IT. Primary control for this light-security drive. **Ext. tools:** Nmap by zone; firewall/ACL rule review.	Drive in a segmented zone; only required flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	Largely **N/A**, but note the 520-series embedded adapter can send **fault email/SMTP notifications**; if that feature is enabled, disable it or restrict SMTP so the drive originates no general-purpose messaging. **Ext. tools:** CCW / embedded web (SMTP/email config) - confirm disabled.	N/A / any email-notification feature disabled.	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose drive; no separable applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm drive faults (CCW/keypad fault queue) and AssetCentre change records are readable/exportable and forwarded to the SIEM; the cell is passively monitored (OT IDS on a mirror port). **Ext. tools:** AssetCentre export; passive OT IDS (mirror port).	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the adapter CIP connection limit plus cell-firewall rate-limiting prevent a flood from denying control; the 520 adapter is more sensitive to scan storms, so confirm firewall rate controls and monitor comms status. **Ext. tools:** Adapter connection review; traffic generator (ISOLATED).	Resources bounded; drive control continues under load.	
SR/CR 7.2	Resource management	Confirm the adapter bounds resource use (fixed CIP connection limit) so a single service cannot starve control. **Ext. tools:** Adapter connection/limits review.	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the parameter set / CCW project is backed up (AssetCentre DR, versioned, offline) and a restore is tested for a known-good rebuild. **Ext. tools:** AssetCentre DR review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.6	Network & security configuration settings	Harden per baseline: disable the embedded **web server** and any **email/SMTP** notification if unused, set comm-fault actions (C143/C144), constrain command sources (P046-P049), and disable unused ports/option functions. **Ext. tools:** CCW / embedded web (disable web/SMTP); Nmap (exposed services).	Least functionality; unused services disabled per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the drive (catalog, firmware rev, option card, adapter) is inventoried so vulnerabilities track against Rockwell Automation security advisories. **Ext. tools:** CCW/AssetCentre inventory; ReadOnlyEnum.	Accurate component/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
CCW / Studio 5000	Native config review (all FRs)	Read Group C (IP, C125/C143/C144 comm-loss), command sources (P046-P049), fault queue, firmware rev; compare to baseline.	Read/authorized project copy.
FactoryTalk Security / Admin Console	Identity & authorization for the AOP (FR1, 2.1)	Read FactoryTalk users/roles that reach the drive; least-privilege check.	Read-only.
FactoryTalk AssetCentre	Audit, change detection & DR (2.8, 3.4, 6.x, 7.3)	Audit config/firmware changes and provide versioned backup/restore for the light-security drive.	Non-intrusive.
ControlFLASH / PCDC	Firmware update & provenance (3.2, 3.10)	Update from verified PCDC files; confirm revision/provenance (no on-drive signature check).	Maintenance window.
Nmap / ReadOnlyEnum / Wireshark	Exposed-service, zone & comms review (1.13, 3.1, 5.x, 7.6)	Enumerate EtherNet/IP + embedded web per zone; confirm cleartext CIP stays in-zone; only required services reachable.	Read-only/passive; authorized.
ENIP/CIP fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed-frame / high-rate EtherNet/IP testing on a bench drive while watching fault queue / connection health.	ISOLATED/non-production; written authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.